

EMAIL THREAT INVESTIGATION & ANALYSIS

Case File CA-ETI-01

Cryptonic Area — Cyber Security & Ethical Hacking Virtual Internship · Project 01 (Email Security)

Prepared by: Jasper I. Talangan

Subject Mailbox: aditya.rao@solvexindustries.com (Mr. Aditya Rao, Senior Finance Executive, Solvex Industries Pvt. Ltd.)

Emails Reviewed: 13

Date of Report: July 27, 2026

1. Executive Summary

Thirteen emails recovered from the mailbox of Mr. Aditya Rao (Senior Finance Executive, Solvex Industries Pvt. Ltd.) were investigated following a suspected fraud attempt flagged by the finance team. Each email was assessed for sender authenticity, header integrity (SPF/DKIM/DMARC), embedded links, attachments, and social-engineering language.

Findings: 5 emails were classified SAFE, 2 as SUSPICIOUS, and 6 as MEDIUM RISK. The MEDIUM RISK emails include credential-harvesting phishing (fake IT/Microsoft alerts), a CEO wire-transfer fraud attempt, a gift-card fraud attempt impersonating the CFO, an advance-fee lottery scam, and a macro-enabled malware attachment disguised as a vendor invoice. Two additional emails (a vendor bank-detail change request and an unsolicited recruiter request for PAN/salary details) show mixed signals — passing authentication but containing behavioral red flags — and are classified SUSPICIOUS pending manual verification.

The pattern across the MEDIUM RISK emails is consistent: attackers are using urgency, authority (impersonating executives or IT/Microsoft), and secrecy (“don't discuss with anyone” / “don't call”) to bypass normal verification steps, which is a classic combination for both credential theft and Business Email Compromise (BEC) financial fraud.

2. Email-by-Email Analysis

Email 1/13 — "Password Expiry Reminder – Action Needed Within 5 Days"

Verdict: **SAFE**

Evidence:

- Sender ithelpdesk@solvexindustries.com matches company domain; Reply-To and Return-Path consistent.
- SPF, DKIM, DMARC all Pass; TLS 1.3 encrypted; internal received-from IP (192.168.14.22).
- No embedded link, no attachment. Tone is calm and informational, includes a genuine security reminder ("do not share your password with IT").

Social engineering tactics: None — no urgency or fear tactics used.

Recommended action: No action needed. File as a legitimate baseline example of internal IT communication.

Email 2/13 — "URGENT: Your Mailbox Storage is FULL – Verify Now to Avoid Suspension"

Verdict: **MEDIUM RISK**

Evidence:

- Display name "IT Support Desk" but sending domain is solvex-industries-helpdesk.com — a lookalike of the real solvexindustries.com (extra "-helpdesk" inserted).
- Reply-To (recovery-team@mail-secure-verify.net) and Return-Path (bounce@mail-secure-verify.net) both point to an unrelated third-party domain, not the sender's own domain.
- Received from an unknown host on a .ru (Russia) static cloud IP (193.41.77.108) — not a Solvex or expected mail infrastructure.
- SPF, DKIM, DMARC all Fail (DMARC reject policy overridden); unencrypted.
- BCC'd to a bulk list (allstaff-list223@...) — mass phishing indicator.
- Embedded link points to solvex-industries-helpdesk.verify-account-secure.com — a credential-harvesting lookalike domain, not the real company domain.

Social engineering tactics: Urgency ("IMMEDIATELY", "final notice") and fear (permanent loss of mailbox access).

If the recipient had acted on it: Clicking the link would lead to a fake login page designed to steal Aditya's real email credentials, giving the attacker access to his mailbox.

Recommended action: Do not click. Report to IT/Security, block sender domain and IP, and add solvex-industries-helpdesk.com and verify-account-secure.com to the email/web blocklist.

Email 3/13 — "Invoice SI-4471 & Updated Bank Details for Future Payments"

Verdict: **SUSPICIOUS**

Evidence:

- Sender domain apex-steeltraders.co passes SPF/DKIM/DMARC — authentication is technically valid for that domain.
- However, Reply-To (accounts.payments@apexsteel-billing.com) is a different domain from both the From address and Return-Path — replies would not go back to the apparent sender.
- Body requests an urgent change to the vendor's bank account ("payments... should be made to our NEW account... effective immediately") combined with a deadline ("close this quarter's books by the 10th").

Social engineering tactics: Urgency (book-closing deadline) and authority (formal accounts-department request) used to rush a banking change without independent verification.

If the recipient had acted on it: If paid without verification and the request is fraudulent, the payment (Rs. 4,85,600) would go directly to an attacker-controlled account with little chance of recovery.

Recommended action: Do not update payment details from this email alone. Call Apex Steel Traders using a known, previously verified phone number to confirm the bank change before processing any payment.

Email 4/13 — "Revised Leave & Work-From-Home Policy – Effective 15 July 2026"

Verdict: **SAFE**

Evidence:

- Sent from hr@solvexindustries.com to all-employees@solvexindustries.com — consistent internal domain throughout.
- SPF, DKIM, DMARC all Pass; TLS 1.3; internal IP.
- No link or attachment requiring action outside the internal HR portal; content is a routine policy announcement.

Social engineering tactics: None.

Recommended action: No action needed. Routine internal HR communication.

Email 5/13 — "Confidential – Immediate Wire Transfer Required (Time Sensitive)"

Verdict: **MEDIUM RISK**

Evidence:

- Display name "Rajeev Malhotra (Managing Director)" but the address is rajeev.malhotra.md@gmail-corpmail.com — not a Solvex domain and not a real free-mail provider either (deceptive lookalike of "gmail").
- Domain has no SPF record; DKIM and DMARC both None; unencrypted; relayed through a free/anonymous mail host in the Netherlands.
- Classic Business Email Compromise (BEC) / CEO fraud pattern: urgent international wire transfer, told to keep it secret from Accounts.

Social engineering tactics: Urgency ("within the next hour"), authority (impersonating the MD), and secrecy ("do not discuss this with Priya or anyone in Accounts") — explicitly isolating the target from the people who would normally verify the request.

If the recipient had acted on it: If Aditya complied, USD 18,500 would be wired directly to an attacker-controlled account, with the secrecy instruction specifically designed to delay discovery.

Recommended action: Do not action. Verify any executive payment request via a separate, known channel (phone call to the MD directly) before ever initiating a transfer, and report the email to IT/Security immediately.

Email 6/13 — "'Q1_Vendor_Compliance_Report.xlsx' has been shared with you"

Verdict: **SAFE**

Evidence:

- Sender is the legitimate drive-shares-noreply@google.com, SPF/DKIM/DMARC all Pass, TLS 1.3, received from Google's own infrastructure (mail-sor-f89.google.com).
- Embedded link resolves to docs.google.com, Google's real domain — not a lookalike.
- Content references a named, real colleague (priya.menon@solvexindustries.com) and a plausible business context (finance sync, audit call).

Social engineering tactics: Mild urgency (“before Friday’s audit call”) but consistent with normal workplace deadlines, not a manipulation tactic on its own.

Recommended action: Low concern, but as good practice, briefly confirm with Priya directly (in person/chat) that she did share this file, since Google Drive notification emails can occasionally be spoofed-adjacent via compromised accounts.

Email 7/13 — "Unusual sign-in activity detected on your Microsoft account"

Verdict: MEDIUM RISK

Evidence:

- Sending domain is micros0ft-online.com — a typosquat using a zero in place of the letter “o”.
- SPF, DKIM, DMARC all Fail; unencrypted; received from an unrelated VPN exit node of unknown origin.
- Embedded link points to login.micros0ft-online.com — the same typosquatted domain, built to imitate a real Microsoft login page.

Social engineering tactics: Fear (account compromised) and urgency (“12 hours”) to pressure an immediate, unverified click.

If the recipient had acted on it: Clicking through and entering credentials would hand the attacker Aditya's real Microsoft/Office 365 login, giving direct access to company email, OneDrive, and Teams.

Recommended action: Do not click. Report as phishing; if any credentials were ever entered on a similar page in the past, reset that password and enable MFA immediately.

Email 8/13 — "Exciting Career Opportunity – Senior Finance Role (Immediate Response Needed)"

Verdict: SUSPICIOUS

Evidence:

- Sender domain talentbridge-recruiters.net passes SPF and DKIM, but DMARC has no policy published — meaning spoofed mail using this domain wouldn't reliably be blocked or flagged.
- Requests a scanned salary slip and PAN card (government ID) be sent back within 24 hours — sensitive personal/financial data collection very early in an unsolicited recruitment contact.
- Attachment is a .zip archive (JD_SeniorFinanceManager_Client.zip) — an unusual and risk-prone format for a simple job description document.

Social engineering tactics: Greed (40% above-average salary) and urgency (24-hour reply, “client wants to close this week”) used to rush a decision to share sensitive personal documents and/or open the attachment.

If the recipient had acted on it: Opening the zip could execute malware if it contains a disguised executable; separately, sending a PAN card and salary slip to an unverified recruiter risks identity theft or financial fraud.

Recommended action: Do not open the attachment or send any personal documents. Independently verify TalentBridge Recruiters exists and is engaged by the claimed MNC client before any further contact.

Email 9/13 — "Your TallyPrime Cloud Subscription Renewal Invoice – INV-88213"

Verdict: SAFE

Evidence:

- Sender billing@tallysolutions.com — SPF, DKIM, DMARC all Pass, TLS 1.3, sent from Tally's own outbound mail server.
- Explicitly states “no bank details have changed” and directs payment to the existing registered method — the opposite pattern of a fraud attempt.

- Attachment is a plain PDF invoice, an expected format for this type of document.

Social engineering tactics: None.

Recommended action: No action needed beyond normal invoice processing through established payment channels.

Email 10/13 — "CONGRATULATIONS!!! YOU HAVE WON USD 1,000,000 IN THE INTERNATIONAL EMAIL LOTTERY"

Verdict: MEDIUM RISK

Evidence:

- Sender claims.department009@yandex-mailer.com with SPF/DKIM/DMARC all Fail, sent unencrypted via an unrelated free-hosting relay in the Netherlands.
- Addressed to "undisclosed-recipients" with Aditya only BCC'd — classic mass-spam distribution pattern, not a targeted legitimate message.
- Requests a USD 250 "processing fee" and personal ID before any prize is released — a textbook advance-fee fraud structure.
- Embedded link (claim-your-prize-now.lottery-verify.info) is an unrelated scam domain.

Social engineering tactics: Greed (a life-changing cash prize) and urgency (48-hour forfeiture deadline).

If the recipient had acted on it: Paying the "fee" results in direct financial loss with no prize ever delivered; submitting ID enables identity theft.

Recommended action: Delete/report as spam. No legitimate lottery requires payment or ID to release winnings that were never entered for.

Email 11/13 — "Quick request before my flight"

Verdict: MEDIUM RISK

Evidence:

- From address suresh.iyer@solvexindustries.com is the real internal domain and technically passes SPF/DKIM/DMARC.
- However, Reply-To is set to s.iyer.cfo.travel@outlook.com — an external free-mail address — meaning any reply would leave the company's mail system entirely rather than reaching the real CFO account.
- Requests purchasing five Rs. 5,000 Amazon gift cards and sending the codes by email — a well-known gift-card fraud pattern that has no legitimate business justification.

Social engineering tactics: Urgency ("20 minutes before boarding"), authority (impersonating the CFO), and an explicit instruction to avoid verification ("don't call the office landline").

If the recipient had acted on it: If purchased and the codes emailed, the funds (Rs. 25,000) would be immediately and irreversibly redeemed by the attacker — gift card codes cannot be recalled once shared.

Recommended action: Do not purchase anything. This should be verified by phone through a known, independently-dialed number for Suresh Iyer — never a number or channel provided within the suspicious email itself. Report the account/Reply-To discrepancy to IT Security, as it may indicate a compromised or spoofed internal account.

Email 12/13 — "Reminder: Mandatory Security Awareness Training – Due This Friday"

Verdict: SAFE

Evidence:

- Sent from infosec@solvexindustries.com to all-employees@solvexindustries.com, fully internal and consistent.
- SPF, DKIM, DMARC all Pass, TLS 1.3, internal IP.
- No link outside the known internal learning portal domain (learn.solvexindustries.com), no attachment.

Social engineering tactics: None.

Recommended action: No action needed. Recommend Aditya completes the training given the live fraud attempts documented in this case.

Email 13/13 — "Pending Invoice – Please Review & Process on Priority"

Verdict: MEDIUM RISK

Evidence:

- Sending domain shreeganesh-logistics.in fails SPF ("domain not authorised to send"), has no DKIM, and fails DMARC; sent unencrypted from an unrelated shared-hosting cluster, not the vendor's own infrastructure.
- Attachment is a macro-enabled Word document (Pending_Invoice_Challan_Details.docm) — a well-known malware delivery format.
- Body explicitly instructs the recipient to "enable editing/macros if prompted" — the single biggest red flag in the entire case file, as this is the exact social-engineering step required for a malicious macro to execute.
- Embedded link uses a deceptive nested-subdomain trick (shreeganesh-logistics.in.invoice-view-secure.com) designed to look like the real vendor domain at a glance.

Social engineering tactics: Urgency ("overdue for closing this month") combined with a technical-sounding justification ("older billing system") to explain away the unusual macro request.

If the recipient had acted on it: Enabling macros would very likely execute malicious code on Aditya's machine — potentially installing malware, ransomware, or a backdoor, with financial data on the machine at direct risk.

Recommended action: Do not open the attachment or enable macros under any circumstance. Delete/report, and verify any real invoice from Shree Ganesh Logistics through a previously known contact channel.

3. Indicators of Compromise (IOCs)

Consolidated list of every suspicious domain, IP, URL, and file identified across the 13 emails, with source and reasoning.

Type	Indicator	Where Found / Why Suspicious
Domain	solvex-industries-helpdesk.com	Lookalike of solvexindustries.com; Email 2 sender
Domain	mail-secure-verify.net	Reply-To / Return-Path, Email 2
Domain	solvex-industries-helpdesk.verify-account-secure.com	Credential-harvesting link, Email 2
IP	193.41.77.108 (.ru static cloud)	Received-From, Email 2
Domain	apexsteel-billing.com	Mismatched Reply-To, Email 3
Domain	gmail-corpmail.com	Fake MD sender domain, Email 5 (BEC)
IP	45.137.22.9 (Netherlands relay)	Received-From, Email 5
Domain	micros0ft-online.com	Typosquat (0 for o), Email 7
URL	hxxp://login.micros0ft-online.com/secure/verify-identity	Credential phishing link, Email 7
IP	77.91.134.6 (VPN exit, unknown origin)	Received-From, Email 7
File	JD_SeniorFinanceManager_Client.zip	Risky archive attachment, Email 8
Domain	yandex-mailer.com	Lottery scam sender, Email 10
Domain	outlook-verify.info	Mismatched Reply-To, Email 10
URL	hxxp://claim-your-prize-now.lottery-verify.info/claim	Advance-fee scam link, Email 10
IP	185.220.101.44 (Netherlands)	Received-From, Email 10 (known anonymization relay range)
Domain	s.iyer.cfo.travel@outlook.com (Reply-To)	Gift-card fraud reply hijack, Email 11
Domain	shreeganesh-logistics.in	Fails SPF; malware/invoice fraud, Email 13
File	Pending_Invoice_Challan_Details.docm	Macro-enabled malware dropper, Email 13
URL	hxxp://shreeganesh-logistics.in.invoice-view-secure.com/download	Nested-subdomain phishing link, Email 13
IP	41.203.88.17 (unrelated hosting cluster)	Received-From, Email 13

4. Tools Used for Verification

The following OSINT approaches would be used to independently confirm the malicious nature of the flagged indicators (recommended verification workflow for this case):

- VirusTotal — submit the .zip (Email 8) and .docm (Email 13) attachments and all flagged URLs to check reputation across multiple antivirus/security engines.

- urlscan.io — sandbox-scan the embedded links from Emails 2, 7, 10, and 13 to observe final redirect destination and page content without directly visiting them.
- MXToolbox — verify SPF/DKIM/DMARC record configuration for the sending domains (e.g. confirm gmail-corpmail.com and microsoft-online.com have no legitimate mail authentication set up).
- Google Safe Browsing / WHOIS lookup — check domain registration age and flagged status for the lookalike domains (verify-account-secure.com, lottery-verify.info, invoice-view-secure.com).

Note: URLs in this report are defanged (hxxp://) per standard analyst practice; none were directly visited during this investigation to avoid triggering payloads or alerting the threat actor.

5. Recommended Actions

Immediate (per flagged email)

- Block sender domains/IPs listed in the IOC table at the email gateway and firewall.
- Do not process the vendor bank-detail change (Email 3) or the invoice from Shree Ganesh Logistics (Email 13) without independent phone verification.
- Report Emails 2, 5, 7, 10, 11, and 13 to IT Security for takedown/blocklisting; preserve headers for law-enforcement reporting if financial loss is suspected.
- Investigate whether the CFO's mailbox (Email 11) or reply routing has been compromised, given the internal-passing headers with an external Reply-To.

Organizational (preventive)

- Implement a mandatory callback-verification policy for any request to change vendor bank details or make an urgent/confidential wire transfer, regardless of who appears to send it.
- Enforce strict DMARC (p=reject) on the solvexindustries.com domain and monitor for lookalike domain registrations (typosquat monitoring).
- Block macro execution by default for documents received via email from external senders.
- Reinforce security awareness training (Email 12) with real examples from this case, particularly gift-card and CEO/CFO wire-fraud patterns, which specifically instruct targets to bypass phone verification.
- Restrict use of free-mail-based Reply-To addresses on internal-domain emails via mail-flow rules, and alert when From and Reply-To domains diverge.